DEVSECOPS / SHIFT LEFT

# SECURITY IS NOT A SPRINT

Security hardening retroactively is 10× more expensive than building it in. Shift-left means treating security as a continuous engineering discipline: rotate credentials, scan dependencies, enforce least-privilege, and run automated security tests in CI on every commit.

KEY BENEFITS

- ✓ Reduces cost of fixing vulnerabilities by 10–100× versus post-launch remediation
- ✓ Automated scanning catches CVEs before they ever reach production
- ✓ Prevents credential leaks that can take down a product within hours
- ✓ Builds a compliance evidence trail continuously rather than scrambling pre-audit

REAL-WORLD EXAMPLE

*Log4Shell (2021) exploited a dependency issue present in millions of projects. Organisations with automated SBOM scanning patched it in hours. Others took weeks — some were breached before they knew they were vulnerable.*

PRACTICAL EXAMPLE

*Every pull request automatically runs OWASP dependency-check. A developer adds a logging library with a known CVE. The pipeline blocks the merge and links to the remediation. The vulnerability never reaches production.*

REFLECTION QUESTION

*Does security sit at the end of your development process, or is it embedded from the first commit?*